Corporate Banking Cybersecurity Incident Response Policy

Version 4.0. Effective January 1, 2025. Policy owner: Head Of Compliance.

Purpose

The purpose of this document is to describe the controls, responsibilities and escalation paths that protect clients, employees and the firm. It is designed to be proportionate to the risks of the business while remaining practical for front-office and support functions. This policy sets out the minimum standards that apply across the division and supports the firm's obligations under applicable law and regulation.

Scope

Where local regulation is stricter than this policy, the local requirement prevails and must be documented in a country addendum. The policy applies to all permanent employees, contractors and consultants, including staff seconded from other legal entities of the group. It covers activity conducted on firm premises, remotely, and while travelling on firm business.

Definitions

Policy owner means the senior manager accountable for maintaining this document and for approving interpretations of it. First line of defence refers to the business units that own and manage risk in their day-to-day activities. Employee means any person engaged by the firm under a contract of employment, including fixed-term and part-time staff.

Policy Requirements

1. Severity-one incidents must be escalated to the divisional Chief Operating Officer within 45 minutes of confirmation. Controls are tested quarterly by the first line of defence.

2. A post-incident review must be completed within 5 days of closing a severity-one or severity-two incident. This requirement is monitored through automated surveillance.

Roles and Responsibilities

Line managers are accountable for ensuring their teams understand and follow the policy, and for completing attestations on time. The Compliance function provides advice, monitoring and periodic testing of the controls described here.

Monitoring and Reporting

Exceptions, breaches and near misses are recorded in the operational risk system within five business days of identification. Management information produced under this policy must be reconciled to source systems before it is presented to any governance forum.

Exceptions

All approved exceptions are recorded in the central exceptions register and reviewed quarterly by the policy owner. Exceptions must be requested in writing, include a risk assessment and a remediation plan, and are valid for no longer

than twelve months.

Breaches

Breaches of this policy may lead to disciplinary action, up to and including termination of employment, and may be reported to regulators. Employees who identify a breach should report it promptly to their manager or to Compliance; good-faith reporting is protected.

Review

The policy owner reviews this document at least annually or following a material change in regulation, business model or risk profile. Material changes require approval by the divisional Risk Committee before publication.